

# Auditoria de *Sistemas*

Fundamentos, técnicas, controles internos e conformidade legal aplicados ao contexto de desenvolvimento e operação de sistemas de informação.

Métricas e Auditoria

Controles Internos

SOX

Governança de TI

ADS

## CONTEÚDO DESTE MÓDULO

- O que é auditoria
- Auditoria interna x externa
- Auditoria de TI
- Papel do auditor de sistemas
- Relação com desenvolvimento de software

## O que é auditoria

Auditoria é um processo sistemático, independente e documentado para obter e avaliar evidências objetivas a fim de determinar em que medida critérios preestabelecidos estão sendo cumpridos. Em outras palavras, é a verificação de que uma organização está fazendo o que diz que faz, da forma correta e dentro das normas aplicáveis.

O conceito vem originalmente da área contábil e financeira, mas se expandiu para abranger processos, sistemas, segurança, qualidade e tecnologia da informação. Em TI, a auditoria analisa se os sistemas, dados e processos tecnológicos suportam os objetivos do negócio de forma segura, eficiente e em conformidade com leis e políticas.

**i** O objetivo central da auditoria **não é punir**, mas identificar riscos, falhas e oportunidades de melhoria para que a organização possa corrigir e evoluir seus processos.

| ELEMENTO             | DESCRIÇÃO                                                            |
|----------------------|----------------------------------------------------------------------|
| Sistemático          | Segue um plano e metodologia definidos, não é aleatório              |
| Independente         | O auditor não pode auditar algo que ele mesmo criou ou gerencia      |
| Documentado          | Todas as evidências e conclusões são registradas formalmente         |
| Evidências objetivas | Baseado em fatos verificáveis, não em opiniões                       |
| Critérios            | Comparação com normas, políticas ou regulações previamente definidas |

## Auditoria interna x externa

As auditorias podem ser conduzidas por profissionais da própria organização (auditoria interna) ou por entidades independentes externas (auditoria externa). Cada uma tem propósito, abrangência e público-alvo distintos.



### Auditoria Interna

Realizada por equipe da própria empresa. Foco em melhoria contínua, controles internos e riscos operacionais. Resultados reportados à alta gestão e ao conselho.



### Auditoria Externa

Conduzida por firma independente, geralmente exigida por lei ou regulação. Emite opinião imparcial para acionistas, órgãos reguladores e mercado.

| CRITÉRIO             | INTERNA                     | EXTERNA                        |
|----------------------|-----------------------------|--------------------------------|
| Quem conduz          | Funcionários da organização | Firma independente             |
| Frequência           | Contínua ou periódica       | Anual (em geral)               |
| Público do relatório | Gestão interna              | Acionistas, reguladores        |
| Foco principal       | Eficiência e controle       | Conformidade e transparência   |
| Obrigatoriedade      | Normalmente opcional        | Frequentemente exigida por lei |

## Auditoria de TI

A auditoria de TI (ou auditoria de sistemas de informação) avalia os controles relacionados à infraestrutura tecnológica, sistemas, dados e processos de TI de uma organização. O objetivo é garantir que a TI entregue valor ao negócio, proteja os ativos de informação e opere com integridade.

A ISACA (Information Systems Audit and Control Association) define quatro grandes domínios da auditoria de TI: governança de TI, gerenciamento de serviços, controles de aplicações e segurança da informação.

Governança de TI

Segurança da Informação

Controles de Aplicações

Gestão de Riscos

Continuidade de Negócios

Conformidade Regulatória

⚠ Auditar TI vai além de verificar se os servidores estão funcionando. Envolve avaliar **políticas, processos, pessoas e tecnologias** de forma integrada.

## Papel do auditor de sistemas

O auditor de sistemas atua como um profissional que combina conhecimento técnico em TI com habilidades analíticas e metodológicas de auditoria. Não se trata de um desenvolvedor nem de um operador de TI, mas de alguém capaz de avaliar criticamente como os sistemas são construídos, operados e controlados.

**01 Planejar a auditoria:** definir escopo, objetivos, riscos a serem avaliados e recursos necessários para a execução.

**02 Coletar evidências:** utilizar técnicas como entrevistas, análise de logs, testes de controles e revisão de documentação.

**03 Avaliar controles:** verificar se os controles implementados são adequados, eficazes e funcionam como esperado.

**04 Comunicar resultados:** elaborar relatórios claros com achados, riscos identificados e recomendações de melhoria.

## Relação com desenvolvimento de software

A auditoria de sistemas está diretamente relacionada ao ciclo de vida de desenvolvimento de software (SDLC). Desenvolvedores criam sistemas que processam, armazenam e transmitem dados — e é sobre esses sistemas que a auditoria irá agir.

Para um desenvolvedor, entender auditoria significa escrever código mais seguro, criar logs adequados, documentar decisões de design e implementar controles que possam ser verificados e auditados posteriormente.

### Conexão fundamental

Todo sistema que processa dados financeiros, pessoais ou estratégicos será objeto de auditoria em algum momento. Conhecer os critérios de auditoria durante o desenvolvimento economiza retrabalho e reduz riscos legais.

| FASE DO SDLC               | INTERESSE DO AUDITOR                                              |
|----------------------------|-------------------------------------------------------------------|
| Levantamento de requisitos | Requisitos de segurança e conformidade foram considerados?        |
| Design                     | A arquitetura suporta controles de acesso e rastreabilidade?      |
| Desenvolvimento            | O código segue boas práticas de segurança? Há code review?        |
| Testes                     | Existem testes de segurança? Os erros são tratados corretamente?  |
| Deploy e operação          | O sistema gera logs? Há controle de acesso ao ambiente produtivo? |
| Manutenção                 | Mudanças passam por processo de gerenciamento de mudanças?        |



## CONTEÚDO DESTE MÓDULO

- Planejamento de auditoria
- Coleta de evidências
- Testes de controle
- Entrevistas, documentos e observação
- Relatórios de auditoria

## Planejamento de auditoria

O planejamento é a fase mais crítica do processo de auditoria. Um planejamento inadequado compromete a eficácia de todo o trabalho. Nessa etapa, define-se o que será auditado, como e por quê, considerando os riscos da organização e os recursos disponíveis.



### Definição do escopo

Delimitar quais sistemas, processos ou unidades organizacionais serão avaliados no ciclo de auditoria.



### Avaliação de riscos

Identificar os principais riscos que podem afetar os objetivos organizacionais e priorizar o que merece atenção.



### Cronograma e recursos

Estimar o tempo, pessoal especializado e ferramentas necessárias para executar a auditoria de forma adequada.



### Programa de auditoria

Documento que detalha os procedimentos específicos a serem executados para cada área ou objetivo de auditoria.

**i** O **programa de auditoria** (audit program) é o "roteiro" que guia o auditor durante a execução. Ele lista cada procedimento, quem é responsável e qual evidência deve ser obtida.

## Coleta de evidências

Evidências são a base de qualquer conclusão de auditoria. Uma evidência válida deve ser suficiente (em quantidade), confiável (proveniente de fonte idônea), relevante (relacionada ao objetivo avaliado) e útil (que ajude a atingir a conclusão).

| TIPO DE EVIDÊNCIA | EXEMPLOS EM TI                                             | CONFIABILIDADE         |
|-------------------|------------------------------------------------------------|------------------------|
| Física            | Foto de servidor sem rack trancado, impressão de relatório | Alta                   |
| Documental        | Políticas, contratos, logs de sistema, e-mails             | Alta (se autêntica)    |
| Testimonial       | Depoimentos em entrevista, declarações                     | Média                  |
| Analítica         | Análise de tendências, comparações, CAATs                  | Alta (se bem aplicada) |
| Observacional     | Observação direta de um processo sendo executado           | Alta                   |

✔ **CAATs** (Computer-Assisted Audit Techniques) são ferramentas e técnicas de auditoria assistidas por computador, como scripts SQL para analisar bases de dados e identificar transações suspeitas.

## Testes de controle

Os testes de controle verificam se os controles implementados estão operando de forma eficaz. Diferem dos testes substantivos, que verificam os próprios dados e transações. Em auditoria de TI, os testes de controle são fundamentais para avaliar a confiabilidade dos sistemas.

**01 Teste de existência:** verificar se o controle está implementado (ex: existe uma política de senhas?)

**02 Teste de funcionamento:** verificar se o controle funciona como descrito (ex: a política de senhas é realmente aplicada pelo sistema?)

**03 Teste de eficácia:** verificar se o controle alcança o objetivo pretendido (ex: o controle de senhas realmente previne acessos não autorizados?)

**04 Teste de continuidade:** verificar se o controle operou de forma consistente durante todo o período auditado.

### Exemplo – Teste de controle de acesso (SQL)

```
-- Verificar usuários com acesso privilegiado não autorizado
SELECT user_id, username, role, last_access
FROM system_users
WHERE role IN ('ADMIN', 'DBA', 'ROOT')
      AND user_id NOT IN (
          SELECT user_id FROM authorized_privileged_users
      )
ORDER BY last_access DESC;
```

## Entrevistas, documentos e observação

As principais técnicas qualitativas de coleta de evidências são entrevistas com responsáveis pelos processos, análise de documentação e observação direta. Cada uma tem suas vantagens e limitações.



### Entrevistas

Conversas estruturadas com gestores, desenvolvedores e operadores de TI para entender processos, responsabilidades e riscos. Úteis para obter contexto, mas dependem da boa-fé do entrevistado.



### Análise documental

Revisão de políticas, procedimentos, contratos, arquiteturas de sistema, logs e registros de mudanças. Evidência mais objetiva, mas documentos podem estar desatualizados.



### Observação direta

O auditor acompanha a execução real de um processo. Revela discrepâncias entre o documentado e o praticado, mas o observado pode mudar o comportamento dos colaboradores.



### Re-execução

O auditor executa ele mesmo um procedimento para verificar se os resultados são consistentes com os descritos. Alta confiabilidade, mas consome mais tempo.

⚠ Boas práticas recomendam **triangulação**: combinar pelo menos duas ou três técnicas diferentes para corroborar uma mesma evidência antes de tirar conclusões.

## Relatórios de auditoria

O relatório de auditoria é o produto final do trabalho do auditor. Deve ser claro, objetivo, fundamentado em evidências e útil para quem irá tomar decisões a partir dele. Um bom relatório identifica achados, avalia o risco associado a cada um e apresenta recomendações práticas.

| SEÇÃO DO RELATÓRIO   | CONTEÚDO                                                                    |
|----------------------|-----------------------------------------------------------------------------|
| Sumário executivo    | Visão geral do escopo, objetivos e principais conclusões para a alta gestão |
| Escopo e metodologia | O que foi avaliado, como e em qual período                                  |
| Achados              | Desvios ou vulnerabilidades identificadas, com evidências                   |
| Avaliação de risco   | Classificação de cada achado (crítico, alto, médio, baixo)                  |
| Recomendações        | Ações corretivas ou preventivas sugeridas pelo auditor                      |
| Resposta da gestão   | Plano de ação da área auditada com prazos e responsáveis                    |

### ✦ Boas práticas na redação

Cada achado deve seguir a estrutura **Condição → Critério → Causa → Efeito → Recomendação**. Isso garante clareza sobre o que foi encontrado, qual era o padrão esperado, por que ocorreu, qual impacto tem e o que fazer para corrigir.

## CONTEÚDO DESTE MÓDULO

- O que são controles internos
- Controles preventivos, detectivos e corretivos
- Controles no desenvolvimento de software
- Controles na operação de sistemas
- Governança de TI

## O que são controles internos

Controles internos são políticas, procedimentos, práticas e estruturas organizacionais concebidas para fornecer razoável garantia de que os objetivos do negócio serão alcançados e que eventos indesejáveis serão prevenidos ou detectados e corrigidos.

O framework COSO (Committee of Sponsoring Organizations) é o modelo de referência mais amplamente adotado para controles internos. Ele define cinco componentes interdependentes: ambiente de controle, avaliação de riscos, atividades de controle, informação e comunicação, e monitoramento.



### Ambiente de controle

A cultura organizacional, o tom da liderança e os valores éticos que formam a base para todos os outros controles.



### Avaliação de riscos

Processo de identificar e analisar riscos relevantes para o alcance dos objetivos, como base para determinar como gerenciá-los.



### Atividades de controle

Políticas e procedimentos que ajudam a garantir que as diretrizes de gestão sejam executadas.



### Monitoramento

Avaliação contínua ou periódica da qualidade dos controles internos ao longo do tempo.

## Controles preventivos, detectivos e corretivos

Os controles são classificados de acordo com o momento em que atuam em relação a um evento de risco. Uma estratégia de controle robusta utiliza os três tipos de forma complementar.



### Preventivos

Atuam antes do evento indesejado, impedindo que ele ocorra.

Exemplos em TI: autenticação multifator, controles de acesso baseados em perfil (RBAC), validação de entrada de dados, criptografia.



### Detectivos

Atuam durante ou após o evento, identificando que algo indesejado ocorreu.

Exemplos em TI: logs de auditoria, sistemas de detecção de intrusão (IDS), alertas de transações suspeitas, reconciliações.



### Corretivos

Atuam após a detecção do evento, corrigindo o problema e restaurando a normalidade.

Exemplos em TI: plano de recuperação de desastres, rollback de transações, patch de segurança, restauração de backup.

**A defesa em profundidade** (defense in depth) é o princípio de usar camadas de controles dos três tipos, de modo que a falha de um não comprometa todo o sistema de proteção.

## Controles no desenvolvimento de software

Durante o ciclo de desenvolvimento, é possível e necessário implementar controles que garantam a qualidade, segurança e rastreabilidade do software produzido. Esses controles fazem parte do que se chama de SDLC seguro (Secure SDLC).

**01 Controle de versão:** uso de sistemas como Git para rastrear todas as alterações no código, com identificação de quem fez o quê e quando.

**02 Code review:** exigência de revisão por outro desenvolvedor antes de qualquer merge em branch principal — controle preventivo contra bugs e vulnerabilidades.

**03 Separação de ambientes:** manter ambientes distintos de desenvolvimento, homologação e produção, impedindo que código não testado chegue aos usuários.

**04 Testes automatizados:** testes unitários, de integração e de segurança (SAST/DAST) como parte do pipeline de CI/CD.

**05 Gerenciamento de mudanças:** toda alteração em produção deve ser aprovada, documentada e testada — impedindo mudanças não autorizadas.

### Exemplo – Pipeline CI/CD com controles de auditoria

```
stages:
  - lint          # controle preventivo: verifica padrão do código
  - test          # controle preventivo: testes automatizados
  - sast_scan     # controle preventivo: análise estática de segurança
  - code_review   # controle preventivo: aprovação obrigatória
  - deploy_stg    # deploy em homologação (não produção!)
  - smoke_test    # controle detectivo: teste pós-deploy
  - deploy_prod   # deploy em produção (apenas após aprovação)
  - audit_log     # registra quem fez o deploy, quando e o quê
```

## Controles na operação de sistemas

Após o software ser colocado em produção, um conjunto de controles operacionais garante que o sistema continue funcionando de forma segura, disponível e íntegra ao longo do tempo.

| CATEGORIA                | CONTROLE                    | OBJETIVO                                                         |
|--------------------------|-----------------------------|------------------------------------------------------------------|
| Acesso lógico            | IAM, RBAC, MFA              | Garantir que apenas usuários autorizados acessem dados e funções |
| Logs e monitoramento     | SIEM, log centralizado      | Detectar e investigar atividades suspeitas                       |
| Backup e recuperação     | Backup 3-2-1, DRP           | Garantir disponibilidade e recuperação em caso de falha          |
| Gerenciamento de patches | Ciclo de patching mensal    | Corrigir vulnerabilidades conhecidas antes que sejam exploradas  |
| Separação de funções     | Segregation of duties (SoD) | Impedir que uma única pessoa controle todo um processo crítico   |
| Continuidade             | BCP, testes de DR           | Manter operações essenciais em situações de crise                |

## Governança de TI

Governança de TI é o conjunto de estruturas, processos e mecanismos que garantem que a TI da organização suporte e potencialize a estratégia de negócios, gerenciando riscos de forma adequada e assegurando o uso responsável dos recursos.

Os principais frameworks de governança e gerenciamento de TI são o COBIT (Control Objectives for Information and Related Technology), ITIL (IT Infrastructure Library), ISO/IEC 27001 (segurança da informação) e ISO/IEC 38500 (governança corporativa de TI).



### COBIT 2019

Framework da ISACA para governança e gerenciamento de TI. Define objetivos de controle organizados em domínios e processos alinhados ao negócio.



### ITIL 4

Conjunto de boas práticas para gerenciamento de serviços de TI, cobrindo o ciclo de vida completo dos serviços desde o design até a melhoria contínua.



### ISO/IEC 27001

Norma internacional para Sistemas de Gestão de Segurança da Informação (SGSI). Certificável e amplamente reconhecida por reguladores e parceiros.

### 🔑 Por que governança importa para desenvolvedores?

A governança de TI define as regras do jogo para qualquer projeto de software: quem aprova, quais padrões seguir, como gerenciar riscos e como reportar. Desenvolvedores que entendem governança conseguem alinhar seu trabalho técnico aos objetivos estratégicos da organização.

## CONTEÚDO DESTE MÓDULO

- Contexto da SOX
- Por que impacta TI
- Riscos, controles e auditoria SOX
- Software, dados e responsabilidade legal

## Contexto da SOX

A Lei Sarbanes-Oxley (SOX) foi promulgada nos Estados Unidos em 2002, em resposta a uma série de grandes escândalos corporativos que abalaram o mercado financeiro mundial. Os casos Enron, WorldCom e Tyco evidenciaram como fraudes contábeis e falta de transparência podiam destruir empresas inteiras e causar prejuízos bilionários a investidores.

⚡ A Enron, que chegou a ser a sétima maior empresa dos EUA, declarou falência em 2001 após revelar que seus executivos haviam inflado artificialmente os lucros por anos. Mais de 20.000 funcionários perderam seus empregos e economias de aposentadoria.

Assinada pelo presidente George W. Bush, a SOX criou novos padrões de responsabilidade para executivos (CEO e CFO) de empresas de capital aberto, endurece as exigências sobre auditorias independentes e estabelece penalidades criminais severas para fraude corporativa.



### Seção 302

CEO e CFO devem assinar pessoalmente os relatórios financeiros, atestando sua precisão. Qualquer falsidade configura crime federal.



### Seção 404

A gestão deve avaliar e reportar anualmente a eficácia dos controles internos sobre relatórios financeiros. É a seção mais relevante para TI.



### PCAOB

A SOX criou o Public Company Accounting Oversight Board, órgão regulador independente que supervisiona auditorias de empresas públicas nos EUA.



### Penalidades

Executivos que certifiquem relatórios sabidamente falsos podem ser condenados a até 20 anos de prisão e multas de até US\$ 5 milhões.

## Por que impacta TI

Embora a SOX seja uma lei financeira, seus requisitos têm impacto profundo em TI porque praticamente todos os dados financeiros de uma empresa moderna são gerados, armazenados e processados por sistemas de informação. Para que os executivos possam atestar a precisão dos relatórios, precisam garantir que os sistemas que os geram são confiáveis e têm controles adequados.

### 💡 A lógica da SOX em TI

Premissa: Se os sistemas de TI que geram as informações financeiras não são confiáveis, os relatórios financeiros também não serão. Portanto, para assegurar a precisão dos dados financeiros, é necessário auditar e controlar os sistemas que os produzem.

| ÁREA DE TI                  | EXIGÊNCIA SOX                                                                   |
|-----------------------------|---------------------------------------------------------------------------------|
| Controle de acesso          | Apenas usuários autorizados podem alterar dados e relatórios financeiros        |
| Gestão de mudanças          | Alterações em sistemas financeiros devem ser aprovadas, testadas e documentadas |
| Operações de TI             | Disponibilidade e integridade dos sistemas que suportam processos financeiros   |
| Desenvolvimento de software | Controles no SDLC de sistemas que geram dados financeiros                       |
| Backup e recuperação        | Dados financeiros devem ser protegidos e recuperáveis                           |
| Logs de auditoria           | Rastreabilidade de quem acessou e alterou dados financeiros                     |

## Riscos, controles e auditoria SOX

No contexto SOX, a abordagem de auditoria é baseada em riscos: identificar os processos financeiros mais críticos, mapear os sistemas de TI que os suportam, avaliar os riscos de distorção material dos relatórios e testar se os controles mitigam adequadamente esses riscos.

**01 Mapeamento de processos financeiros:** identificar os principais processos (contas a pagar, receitas, folha de pagamento, consolidação) e os sistemas que os suportam.

**02 Identificação de ITGCs:** mapear os Controles Gerais de TI relevantes — acesso, gestão de mudanças, operações e desenvolvimento.

**03 Avaliação de risco de TI:** determinar quais falhas de controle poderiam causar distorção material nos relatórios financeiros.

**04 Teste de controles:** executar testes para verificar se os ITGCs estão operando efetivamente durante todo o período auditado.

**05 Comunicação de deficiências:** reportar fraquezas significativas ou deficiências materiais ao comitê de auditoria e à auditoria externa.

⚠️ Uma **deficiência material** (material weakness) em controles de TI SOX é extremamente séria: pode forçar a empresa a reapresentar relatórios financeiros, colapsar o preço das ações e expor executivos à responsabilidade criminal.



## Relação entre software, dados e responsabilidade legal

A SOX criou uma nova realidade para o desenvolvimento de software corporativo: sistemas que processam dados financeiros não são apenas produtos técnicos, mas instrumentos legalmente regulados. Falhas de design, ausência de controles ou logs inadequados podem ter consequências jurídicas graves.



### Responsabilidade dos executivos

CEOs e CFOs que assinam relatórios são responsáveis pela precisão dos sistemas que os geram. "Não sabia que o sistema tinha falha" não é defesa suficiente.



### Rastreabilidade obrigatória

Todo dado financeiro deve ter trilha de auditoria: quem criou, quem alterou, quando e por quê. Sistemas sem logs adequados não atendem SOX.



### Integridade dos dados

O software deve garantir que dados financeiros não possam ser alterados sem registro e autorização adequados — exigência técnica e legal simultaneamente.



### Retenção de registros

A SOX exige retenção de registros contábeis por no mínimo 7 anos. Sistemas precisam suportar esse requisito de armazenamento e recuperação.

### 🧠 Reflexão para desenvolvedores

Quando você desenvolve um sistema que processa dados financeiros em uma empresa de capital aberto, seu código passa a ter implicações legais. Decisões de design como "não vou implementar logs para economizar espaço" ou "o controle de acesso pode ser simplificado" podem resultar em não-conformidade com SOX — com consequências que vão muito além da área de TI.

| AÇÃO DO DESENVOLVEDOR                   | RISCO SOX ASSOCIADO                                                    |
|-----------------------------------------|------------------------------------------------------------------------|
| Não implementar log de auditoria        | Falta de rastreabilidade — controle insuficiente para SOX              |
| Acesso genérico a dados financeiros     | Violação do princípio do menor privilégio — deficiência de controle    |
| Deploy direto em produção sem aprovação | Ausência de controle de mudanças — risco alto em SOX                   |
| Sem separação dev/homolog/produção      | Risco de alterações não autorizadas em dados financeiros reais         |
| Dados financeiros sem criptografia      | Risco de integridade e confidencialidade — impacta SOX e outras normas |

✓ Adotar práticas de **Secure SDLC**, controle de acesso rigoroso, logging adequado e gerenciamento formal de mudanças não é burocracia — é o que diferencia software corporativo profissional de código amador com risco legal.